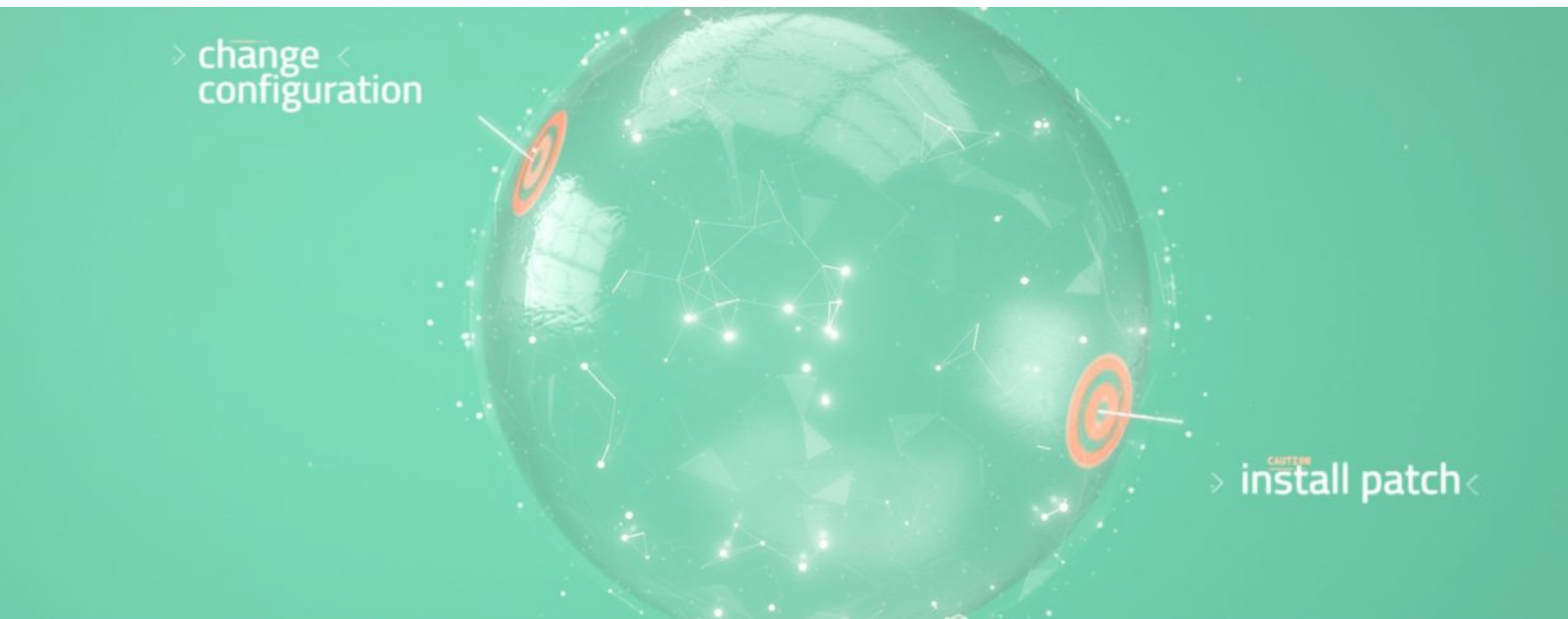


Executive Summary



Email Gateway

Last assessment performed on: 02/02/2023 12:54:49

Last target: danielp@cymail.tk

Last template name: exploits

Last status: Stopped - assessment stopped by user. note: this can affect the final score presented

[Generated full Email Gateway report with the latest results.](#)

Cymulate Demo (Default Environment)

Cymulate's Email Security assessment tests the resiliency of the organization's email systems and security controls. During this assessment solutions such as Secure Email Gateway (SEG), Sandbox, Content Disarm and Reconstruction (CDR), etc, are tested.

The assessment simulates different scenarios which resemble common attack methods used today such as hiding ransomware, malware, and malicious links to avoid detection by embedding them within different file attachments such as zip, html, ics, Microsoft office, etc. and code executions based on exe, com, macros, etc...

Could someone send me a malicious email?

[Phishing: Spearphishing Attachment](#)

[Phishing: Spearphishing Link](#)

Assessment Summary

Cymulate Score

67/100

Your Email security exposure level is: ● Medium

Previous Score: 61/100

Penetration Ratio

6855/13872

Previous Penetration Ratio: 7685/14683

Risk Summary

Score breakdown by risk level

!!!	High Risk	63%		3015/4754
!!	Medium Risk	43%		1227/2827
!	Low Risk	42%		2613/6291

Attack Type Summary

Score breakdown by attack types

	Ransomware	46%		790/1719	30/01/2023 09:58:11	More Info
58 different file types were used to hide Ransomware based behavior. 790 files bypassed your email gateway						
	Malware	45%		2427/5380	30/01/2023 09:58:11	More Info
72 different file types were used to hide Malware based behavior. 2427 files bypassed your email gateway						
	Worm	46%		772/1690	30/01/2023 09:58:11	More Info
58 different file types were used to hide Worm based behavior. 772 files bypassed your email gateway						
	Exploit	78%		71/91	02/02/2023 12:54:49	More Info
	Payload	46%		790/1717	30/01/2023 09:58:11	More Info
58 different file types were used to hide Payload based behavior. 790 files bypassed your email gateway						
	Dummy	59%		1838/3108	30/01/2023 09:58:11	More Info
1838 Files can be used to hide non malicious code execution						
	Links	100%		167/167	30/01/2023 09:58:11	More Info

Attack Type Summary Cont.

	True File Type	100%		675/675	30/01/2023 09:58:11	More Info
This attack type doesn't pose any risk, therefore, it is not included in the score						
	Code In Email Body	0%		0/0	Not Tested	More Info
	Email Policy	99%		135/136	30/01/2023 09:58:11	
This attack type doesn't pose any risk, therefore, it is not included in the score						

Email Gateway Assessment Insights



You are least protected from **Links**

Samples of recent websites that were identified as malicious by known CERTs, security vendors and other threat intelligence engines.

100%



You are most protected from **Malware**

Crafted payloads that use evasion techniques:

- Communicate with C2 via emails
- Collect credentials by forcing prompts of Authentication
- Escalate privileges by forcing prompts of UAC

45%



Archived Files

Such as: Zip, Rar, 7z that may potentially contain malicious code execution and cannot be detected without extraction.

51%



Executable Files

Files that are used to perform various functions or operations on a computer.

.exe .com .scr .pif .vbs .vbe .js .jse .wsf .hta
.bat .cmd .lnk .cpl .dll .msi

84%



Office Files

Such as: Word, Excel, PowerPoint that may potentially contain malicious code execution with a macro or an OLE embedded object.

.doc .dot .wbk .docx .docm .dotm .xlsx .xlsm .xltn .xls
.xlt .xlsb .xla .xlam .xll .xlw .ppt .pot and 10 more..

48%



Email Spoofing

External email with forged sender was blocked.



Links - Rewrite

Malicious URLs have not been rewritten.



True File Type Detection

Attachments with forged extensions were not sent



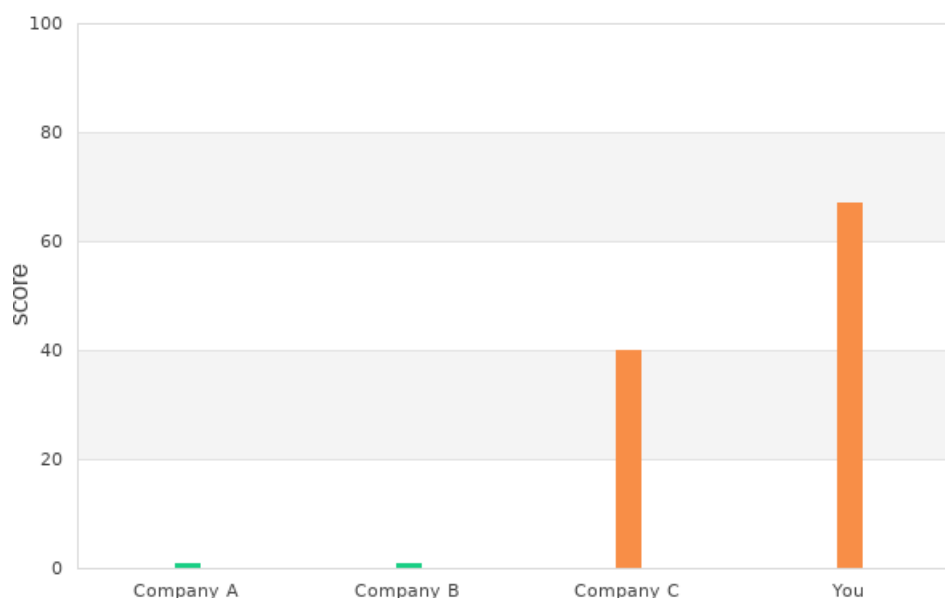
Benchmark - Financial Services

This graph represents your organization exposure score compared with other organizations (Company A, Company B, Company C, You) in your industry globally.

The average score in your industry is: 10

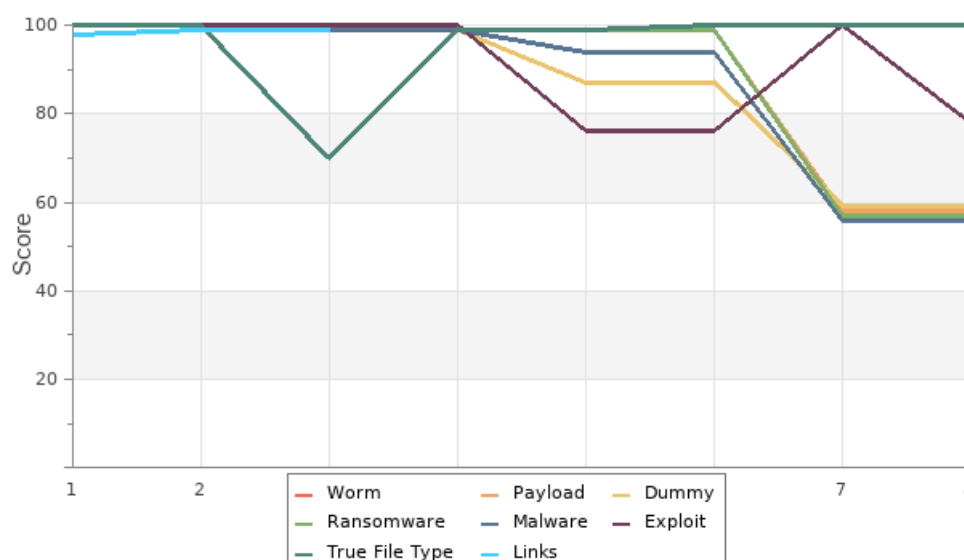
Your score is: 67

*Benchmark was calculated as of 02/02/2023



Performance

This graph represents your performance in each Attack Type over the last 10 assessments



Action Items

File Type Policy

Cymulate recommends blocking nonessential file types (highlighted in red) to solve 3 points of the score by re-configuring and hardening your policy (with no impact to your business):

File types detected by Cymulate as ALLOWED

.mdb	.xlsx	.doc	.dot	.docx	.rtf	.pdf	.ics	.csv	.ppt	.pptx	.accdb	.xls	.vcs
.cab	.jse	.vbs	.zip	.ppsx	.cmd	.xlw	.pwz	.rar	.bz2	.cer	.gzip	.dotm	.arj
.pps	.odt	.ppsm	.xhtml	.7z	.mp3	.jsp	.webm	.potm	.xml	.msg	.xla	.pl	.sct
.diagcab	.xll	.macho	.inf	.vb	.com	.hta	.pif	.scr	.wbk	.lha	.ps1	.pst	.xlb
.bat	.jar	.one	.xsl	.xslm	.c	.swf	.odp	.msi	.sldm	.sldx	.cs	.midi	.pot
.shtml	.vbe	.wsf	.bgi	.mp4	.html	.js	.eml	.pptm	.gz	.xltm	.pkg	.rpm	.diagpkg
.svg	.xll	.htm	.ppa	.mht	.wim	.asm	.war	.slk	.ppam	.oft	.rpm	.hlp	.chm
.mcl	.tiff	.pub	.py	.au3	.nls	.xspf	.docm	.xlm	.xlt	.ods	.xlam	.coff	.sh
.lnk	.php	.tar	.xlsb	.iso	.deb	.elf	.crt	.cpl	.dll	.evtx	.reg	.shtml	.java
.ace	.exe	.img	.tmp	.xz	.cpp	.app	.jpg	.rb					

There are no file types detected by Cymulate as RECONSTRUCTED

File types detected by Cymulate as BLOCKED

.dmg

- File types previously allowed.
- File types previously blocked.

- File types detected by Cymulate as allowed. These file types are considered commonly used by various businesses.
- File types detected by Cymulate as allowed. We recommend reviewing and potentially blocking unnecessary ones to align with your specific business needs.
- File types that have been reconstructed or altered in some way.
- File types detected by Cymulate as blocked.

Security Solutions

If you don't have a security solution that can detect malicious files hidden inside other files, consider re-allocating budgets to replace/add features or add another solution to solve 64 points of your score such as:



- Sandbox
- Content-Disarm & re-construction
- Other security solutions

Appendix A

Attack Types

Dummy

Various files with potential code execution capabilities.
Metasploit payload: use payload/windows/messagebox

[Reference](#)

Code execution description:

Dummy Payload

MessageBox Code Execution file that is not malicious but shows a proof of concept for inserting Code Execution files into the organization. Even though it is not a malicious code, it simulates the possibility for real malicious Code Execution.

Ransomware

Various files with Ransomware based code execution capabilities.

Code execution description:

Cymulate Crypto Ransomware

Encrypts all the files in the current logged on user therefore act as a common ransomware. The file was developed by Cymulate and will not harm the organization. It is not a real live malware therefore signature-based AV engines should not detect it, but it simulates the possibility for real malicious Code Execution.

Worm

Various files with Worm based code execution capabilities.

Code execution description:

Cymulate Worm

Cymulate's Worm will try to Lateral Move using the current primary Token of the user that executed the Worm. The Worm will scan the local network work and try to copy itself to each one of the scanned computers.

The file was developed by Cymulate and will not harm the organization. It is not a real live malware therefore signature-based AV engines should not detect it, but it simulates the possibility for real malicious Code Execution.

Exploit

Various files that exploits a known vulnerability for different software.

Malicious Links

Various known malicious links collected on daily basis from intelligence feeds.

Malware

Various files with Trojan based code execution capabilities.

Code execution description:

Cymulate UAC Nagger

Cymulate's UAC Nagger that attacks the user interface and forcing the user to click Yes when UAC Prompts for authentication. When the user clicks Yes, his elevated permissions token is stolen and potentially can be used for Hopper and Accessing Restricted Data.

The file was developed by Cymulate and will not harm the organization. It is not a real live malware therefore signature-based AV engines should not detect it, but it simulates the possibility for real malicious Code Execution.

Cymulate Cred Nagger

Cymulate's Credentials Nagger that attacks the user interface and forcing the user to enter his username and password by forcing Prompts for authentication. When the user enters the right credentials, his token is stolen and potentially can be used for Hopper and Accessing Restricted Data.

The file was developed by Cymulate and will not harm the organization. It is not a real live malware therefore signature-based AV engines should not detect it, but it simulates the possibility for real malicious Code Execution.

Cymulate Emails Command & Control

Cymulate's Command & Control that uses Outlook connection to the organization email service, listening to different commands from a command and control server using emails to execute different malicious commands.

Command Examples: Get Usernames, Get Emails, Get Printscreen, Send to C&C.

The file was developed by Cymulate and will not harm the organization. It is not a real live malware therefore signature based AV engines should not detect it, but it simulates the possibility for real malicious Code Execution.

Payload

Various files with Payload based code execution capabilities.

Code execution description:

Cymulate Standard Payload

Cymulate's Payload which is a file retrieving general information from local computer like: Usernames, Emails and a Printscreen.

The file was developed by Cymulate and will not harm the organization. It is not a real live malware therefore signature-based AV engines should not detect it, but it simulates the possibility for real malicious Code Execution.

Reverse HTTPS

Meterpreter Reverse Https which is a Metasploit stager downloading Metasploit's Meterpreter payload from a remote server using HTTPS.

The file was created by Metasploit and will not harm the organization as it will not download a malicious Meterpreter payload. It is known as malicious malware therefore AV engine should detect it.



True File Type Detection

A file type is usually represented by its file extension and associated application(s). Each file type has one or more corresponding file extensions. The file extension is appended to the end of each file name which provides a simple way for both operating system and users to identify the file type of each file.

Unfortunately, to bypass security mechanisms a file extension can be changed easily to spoof the operating system and users without modifying the content or changing the capability of the file. Cymulates True file type verification function offers an advanced mechanism to validate a given file type by analyzing the file's structure and content. Using this method we are able to verify the true file type for given files and minimize the risk of file type spoofing

</> Code In Email Body

Sending emails with potentially malicious code in the email body. This technique is commonly used by attackers to phish users, enticing them to copy the code into a relevant platform. By doing so, unsuspecting users may provide an initial foothold to the attacker. Attackers often impersonate Tech Support personnel to lend credibility to their requests.

Appendix B

The Cymulate Score

How is it Calculated?

The Cymulate platform is intended to provide your organization with a quantifiable risk score in order to understand your cyber security risk posture at any time based on the security solutions and capabilities at your disposal.

The following risk rating methods, models, assessments, and methodologies are used for calculating Cymulate assessments risk score:

NIST risk assessment (Special Publication 800-30)

- Threat Likelihood
- Impact

CVSS v3

- Confidentiality
- Integrity
- Availability
- Attack Vector
- Attack complexity
- Privileges Required
- User Interaction
- Remediation Level

DREAD

- Damage
- Reproducibility
- Exploitability
- Affected users
- Discoverability

The algorithm calculates the above factors, also takes into consideration MITRE's ATT&CK framework knowledge base of cyber adversary behavior and taxonomy for adversarial actions across their lifecycle. The result is a number score describing the total exposure level:

Minimal Risk
0-10

Low Risk
11-33

Medium Risk
34-67

High Risk
68-100

***The lower your score, the lower your cyber security risk.**